

Dan Boneh 密码学第一季：第九课 基础密钥交换

本笔记按照课程讲义的主线整理：密钥管理与在线可信第三方 → Merkle Puzzles → Diffie-Hellman 协议 → 中间人攻击 → 公钥加密与密钥传输。

1. 本课要解决什么问题

对称加密和 MAC 都要求通信双方事先拥有共享秘密密钥。但是，当 Alice 第一次与 Bob 通信时，他们怎样通过一个可能被监听的网络建立共享密钥？

密钥交换的目标是：

Alice 与 Bob 最终得到相同的会话密钥，而被动窃听者不能得到该密钥。

本课首先只考虑**被动窃听安全**，即攻击者能读取网络流量，但不能修改、删除或插入消息。随后讲义反复强调：仅抵抗窃听的方案通常不能抵抗主动中间人攻击。

学完本课，应当能够回答：

1. 为什么为每一对用户预先配置对称密钥难以扩展？
2. 在线可信第三方如何帮助分发会话密钥？
3. 为什么玩具 TTP 协议会受到重放攻击？
4. Merkle Puzzles 如何仅使用对称密码实现密钥交换？
5. 为什么合法双方工作量为 $O(n)$ ，而窃听者约为 $O(n^2)$ ？
6. Diffie-Hellman 为什么让双方得到相同的 g^{ab} ？
7. 离散对数、CDH 和 DDH 分别表示什么困难问题？
8. 未认证 Diffie-Hellman 为什么受到中间人攻击？
9. 如何通过公钥加密传输随机会话秘密？
10. 为什么公钥加密本身也不能认证收到的公钥？

2. 密钥管理问题

2.1 预先共享两两密钥的扩展性

假设系统中有 n 个用户，每一对用户都预先共享一把不同的对称密钥。

每个用户需要保存大约：

$$n - 1 = O(n)$$

把密钥。整个系统的用户对数量为：

$$\binom{n}{2} = \frac{n(n-1)}{2} = O(n^2).$$

用户数量增加时，生成、分发、更新和撤销这些密钥会迅速变得困难。

2.2 会话密钥

实际系统通常区分：

- **长期密钥**：长期保存，用于身份认证或保护密钥分发；
- **会话密钥**：为一次连接或一段有限通信临时生成，用于高效的对称认证加密。

使用会话密钥的好处包括：

- 限制单把密钥保护的数据量；
- 便于在会话结束后销毁；
- 不同会话之间相互隔离；
- 可以定期更新密钥。

3. 在线可信第三方 TTP

3.1 基本思想

引入在线可信第三方 Trusted Third Party，简称 TTP。每个用户只需与 TTP 共享一把长期密钥：

- Alice 与 TTP 共享 k_A ；
- Bob 与 TTP 共享 k_B 。

这样每个用户只保存一把或少量长期密钥，整个系统只需 $O(n)$ 份用户到 TTP 的密钥关系。

3.2 玩具协议

Alice 希望与 Bob 建立会话密钥：

1. Alice 向 TTP 请求与 Bob 通信；
2. TTP 随机生成会话密钥 k_{AB} ；
3. TTP 为 Alice 生成：

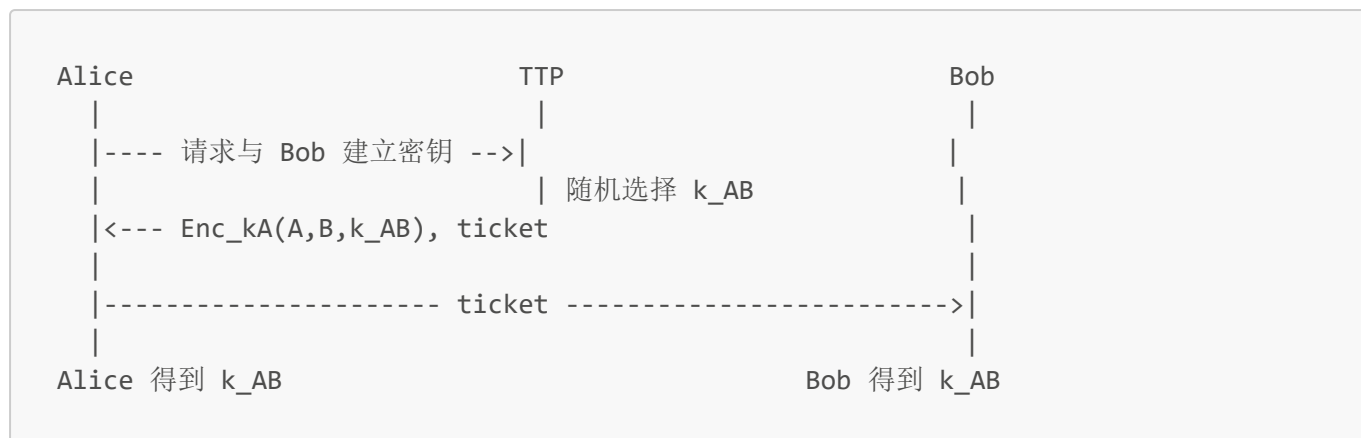
$$c_A = E(k_A, "A,B" \parallel k_{AB});$$

4. TTP 为 Bob 生成 ticket：

$$ticket = E(k_B, "A,B" \parallel k_{AB});$$

5. Alice 解密 c_A 得到 k_{AB} ，并把 ticket 转发给 Bob；
6. Bob 使用 k_B 解密 ticket，得到相同的 k_{AB} 。

流程可以概括为：



3.3 被动窃听安全

窃听者看到的是：

$$E(k_A, "A, B" \parallel k_{AB})$$

和：

$$E(k_B, "A, B" \parallel k_{AB}).$$

若底层加密方案是 CPA 安全的，并且长期密钥保密，窃听者不能从密文中恢复 k_{AB} 。

3.4 局限

TTP 必须始终在线

每次建立新会话都需要联系 TTP。若 TTP 宕机，用户就无法建立会话。

TTP 知道所有会话密钥

TTP 亲自生成 k_{AB} ，因此能够解密所有会话流量。它是高价值攻击目标，也是单点信任。

重放攻击

攻击者可以记录 Alice 以前发送给 Bob 的 ticket 和后续加密订单，再原样重放。Bob 可能认为 Alice 发起了一个新会话或重复下单。

问题在于协议没有证明消息的新鲜性。防重放通常要加入：

- nonce;
- 时间戳;
- 序列号;
- 会话标识;
- 服务端挑战;
- 已使用 ticket 的状态记录。

3.5 与 Kerberos 的关系

讲义指出，该思路是 Kerberos 的基础。真正的 Kerberos 协议使用票据、时间戳、会话密钥和多阶段服务来解决更多身份认证与重放问题，不能把这里的玩具协议直接视为完整 Kerberos。

4. 能否不依赖在线 TTP

公钥密码学诞生前，一个核心问题是：

Alice 和 Bob 能否只通过公开信道建立秘密，而不事先共享密钥，也不在每次会话中联系在线 TTP？

发展过程中的重要节点包括：

- Merkle Puzzles, 1974;
- Diffie-Hellman, 1976;
- RSA, 1977。

Merkle Puzzles 表明，仅使用通用对称密码也可以实现一定意义的密钥交换，不过效率很低。Diffie-Hellman 则利用代数结构获得了指数级的安全差距。

5. Merkle Puzzles

5.1 什么是 Puzzle

Puzzle 是一个可以通过一定计算量解决的问题。

设 E 是 128 位密钥的对称密码。构造一种特殊弱密钥：

$$K_P = 0^{96} \parallel P, \quad P \in \{0, 1\}^{32}.$$

虽然完整密钥长度为 128 位，但只有最后 32 位未知，因此攻击者可以尝试至多 2^{32} 个 P 来解开一个 puzzle。

5.2 Alice 构造 puzzles

一般化地设 Alice 制作 n 个 puzzles。对每个 i ：

1. 随机选择弱密钥部分 P_i ;
2. 随机选择标识 x_i ;
3. 随机选择候选会话密钥 k_i ;
4. 构造：

$\text{puzzle}_i = E(0^{96} \parallel P_i, \text{"Puzzle \#"} \parallel x_i \parallel k_i).$

在讲义的具体参数中：

$$n = 2^{32}.$$

Alice 把所有 puzzles 以随机顺序发送给 Bob。

5.3 Bob 的工作

Bob 随机选择其中一个 puzzle_j ，然后枚举所有 2^{32} 个可能的 P ，直到解密结果包含正确的固定格式“Puzzle #”。

解开后，他得到：

$$(x_j, k_j).$$

Bob 把公开标识 x_j 发给 Alice。Alice 查表找到对应 puzzle，并把 k_j 作为共享秘密。

5.4 为什么窃听者更困难

Alice 知道所有 puzzle 的弱密钥，所以制作 n 个 puzzles 的工作量为：

$$O(n).$$

Bob 只解一个 puzzle，每个 puzzle 的搜索空间为 n ，因此工作量为：

$$O(n).$$

窃听者看到 x_j ，却不知道它对应发送列表中的哪一个 puzzle。它可能要逐个破解 puzzles，直到找到包含 x_j 的那个，工作量约为：

$$O(n^2).$$

当 $n=2^{32}$ 时：

- Alice：约 2^{32} 次基本工作；
- Bob：约 2^{32} 次试验；
- 窃听者：约 2^{64} 次试验。

5.5 安全差距

Merkle Puzzles 实现的是**二次差距**：合法用户花费 n ，窃听者花费 n^2 。

讲义指出，在把对称密码仅当作黑盒 oracle 的模型中，这种二次差距大致是可以达到的最好水平。它具有理论历史意义，但效率不适合作为现代实际密钥交换方案。

5.6 安全边界

本节仍然只考虑被动窃听者。主动攻击者可以替换、删除或伪造 puzzle 和标识，因此还需要身份认证与完整性保护。

6. Diffie-Hellman 密钥交换

6.1 群的高层背景

Diffie-Hellman 在一个适当选择的有限循环群 G 中运行。设：

- G 的阶为 q ；
- g 是生成元；
- 群运算允许高效计算；
- 离散对数等相关问题足够困难。

讲义先用模素数乘法的形式进行直观说明。选择大素数 p 和合适的生成元 g ，在模 p 下计算幂。

实际协议不能随意选择任意 p 和 g ，还要选择安全群或安全子群并验证收到的群元素。

6.2 协议过程

公开参数为 p 和 g 。

Alice:

1. 随机选择秘密指数:

$$a \leftarrow \{1, \dots, q-1\};$$

2. 计算公开值:

$$A = g^a \pmod{p};$$

3. 把 A 发给 Bob。

Bob:

1. 随机选择秘密指数:

$$b \leftarrow \{1, \dots, q-1\};$$

2. 计算公开值:

$$B = g^b \pmod{p};$$

3. 把 B 发给 Alice。

Alice 计算:

$$K_A = B^a = (g^b)^a = g^{ab} \pmod{p}.$$

Bob 计算:

$$K_B = A^b = (g^a)^b = g^{ab} \pmod{p}.$$

因此:

$$K_A = K_B = g^{ab} \pmod{p}.$$

6.3 协议图

公开参数: 群 G 、生成元 g

Alice

秘密选择 a

$$A = g^a$$

Bob

秘密选择 b

$$B = g^b$$

$$A = g^a$$

----->

$$B = g^b$$

<-----

计算 $B^a = g^{(ab)}$

计算 $A^b = g^{(ab)}$

网络上传输的是 A 和 B，而不是 a、b 或 $g^{(ab)}$ 。

6.4 为什么双方结果相同

指数乘法满足交换律：

$$(g^b)^a = g^{ba} = g^{ab} = (g^a)^b.$$

Alice 知道 a 和 B，所以能计算 B^a ；Bob 知道 b 和 A，所以能计算 A^b 。窃听者只知道 g、 g^a 和 g^b 。

6.5 不应直接使用 $g^{(ab)}$ 作为应用密钥

群元素的编码不一定是均匀随机比特串，而且协议还需要派生不同方向和用途的密钥。实际应使用 KDF：

$$K_{session} = KDF(Encode(g^{ab}), transcript, context).$$

其中 transcript 可包含双方身份、公开值 A、B、协议版本和算法信息，以实现上下文绑定与域分离。

7. Diffie-Hellman 的困难问题

7.1 离散对数问题 DLP

已知：

$$g \text{ 和 } A = g^a,$$

求秘密指数 a。

这称为 Discrete Logarithm Problem，简称 DLP。

7.2 计算 Diffie-Hellman 问题 CDH

已知：

$$g^a \text{ 和 } g^b,$$

计算：

$$g^{ab}.$$

这称为 Computational Diffie-Hellman，简称 CDH。讲义把相应函数写成：

$$DH_g(g^a, g^b) = g^{ab}.$$

基础 DH 协议希望窃听者无法计算这个值。

7.3 判定 Diffie-Hellman 问题 DDH

给定：

$$(g^a, g^b, T),$$

判断：

$$T \stackrel{?}{=} g^{ab}$$

还是 T 是一个独立随机群元素。

这称为 Decisional Diffie-Hellman，简称 DDH。DDH 比“直接算出 $g^{(ab)}$ ”提出了更强的不可区分要求，常用于证明由 DH 共享值派生出的秘密具有伪随机性。

7.4 三者关系直觉

若能求离散对数 a ，就可以计算：

$$(g^b)^a = g^{ab},$$

所以能解 DLP 通常意味着能解 CDH。能算出 $g^{(ab)}$ 又能比较 T ，因此能解 CDH 意味着能解 DDH。

反方向不一定成立，不同群中三种假设的性质也可能不同。

问题	输入	目标
DLP	g, g^a	求 a
CDH	g^a, g^b	求 $g^{(ab)}$
DDH	g^a, g^b, T	判断 T 是否为 $g^{(ab)}$

8. 模素数群与椭圆曲线

8.1 模素数 Diffie-Hellman

经典 DH 在模 p 的有限域乘法群或其大素数阶子群中工作。模数越大，已知离散对数算法的成本通常越高，但通信和计算也越慢。

讲义列出的模数与安全级别对照反映了课程制作时期的估计，例如：

对称安全级别	模 p 大小	椭圆曲线群大小
80 位	1024 位	160 位
128 位	3072 位	256 位
256 位	15360 位	512 位

其中 80 位安全和 1024 位有限域参数今天不应作为新系统目标。该表适合用来理解“有限域参数远大于同安全级别的椭圆曲线参数”，而不是直接作为最新部署规范。

8.2 椭圆曲线 Diffie-Hellman

在椭圆曲线群中通常使用加法记号。公开基点为 G ：

- Alice 发送 $A=aG$ ；

- Bob 发送 $B=bG$;
- Alice 计算 $aB=abG$;
- Bob 计算 $bA=abG$ 。

即:

$$a(bG) = abG = b(aG).$$

在相近安全级别下，椭圆曲线通常使用更短的公钥和更少的带宽，因此现代协议广泛使用 ECDH。

9. 中间人攻击

9.1 攻击过程

基础 Diffie-Hellman 没有认证 A 和 B 的来源。攻击者 Mallory 位于 Alice 与 Bob 之间:

1. Alice 发送 $A=g^a$;
2. Mallory 截获 A, 向 Bob 发送自己的 $A'=g^x$;
3. Bob 发送 $B=g^b$;
4. Mallory 截获 B, 向 Alice 发送自己的 $B'=g^y$ 。

Alice 计算:

$$K_{A,M} = (B')^a = g^{ay}.$$

Mallory 用 y 和 A 计算相同密钥:

$$A^y = g^{ay}.$$

Bob 计算:

$$K_{M,B} = (A')^b = g^{xb}.$$

Mallory 用 x 和 B 计算:

$$B^x = g^{xb}.$$

最终 Alice 和 Bob 没有共享同一密钥，而是分别与 Mallory 共享一把密钥。

9.2 攻击者如何转发通信

Mallory 可以:

1. 用 $K_{A,M}$ 解密 Alice 的消息;
2. 阅读或修改明文;
3. 用 $K_{M,B}$ 重新加密并发给 Bob;
4. 对反方向执行相同操作。

Alice 和 Bob 都可能感觉通信正常，却不知道中间人能够读取和篡改全部内容。

9.3 根本原因

Diffie-Hellman 解决的是:

窃听者能否从 g^a 和 g^b 计算共享秘密？

它没有解决：

Alice 收到的 g^b 是否真的由 Bob 发出？

这两个问题分别属于：

- 密钥协商保密性；
- 身份认证与消息来源认证。

9.4 如何获得认证

实际协议会把 DH 临时公钥与身份绑定，例如使用：

- 数字签名；
- 公钥证书和 PKI；
- 预共享密钥上的 MAC；
- 口令认证密钥交换；
- 人工核对短认证字符串；
- 可信公钥指纹。

只对后续数据使用认证加密还不够：如果最初的密钥交换已被中间人分别劫持，攻击者拥有两把合法会话密钥，也能生成正确标签。

10. 两方与多方 Diffie-Hellman

讲义用社交网络示意：每个用户公布自己的 DH 公钥：

$$g^a, g^b, g^c, g^d, \dots$$

Alice 与 Charlie 可以非交互地计算两人共享值：

$$K_{AC} = (g^c)^a = g^{ac},$$

Charlie 也能计算：

$$(g^a)^c = g^{ac}.$$

但是，仅从：

$$g^a, g^b, g^c, g^d$$

让所有四人各自在一轮内得到：

$$g^{abcd}$$

并不像两方 DH 那样直接。普通群运算只支持指数相乘一次，不能从公开的一次幂值自然地产生任意多方乘积。这引出了多方密钥交换和更复杂代数工具的研究问题。

11. 公钥加密

11.1 定义

公钥加密系统由三个算法组成：

$$(G, E, D).$$

密钥生成

$$(pk, sk) \leftarrow G().$$

G 是随机算法，产生：

- pk ：可以公开的公钥；
- sk ：必须保密的私钥。

加密

$$c \leftarrow E(pk, m).$$

加密通常必须随机化。同一公钥和同一消息多次加密，应当通常产生不同密文。

解密

$$m \text{ 或 } \perp \leftarrow D(sk, c).$$

解密通常是确定性算法。

11.2 正确性

对于密钥生成算法输出的任意合法密钥对和任意合法消息：

$$D(sk, E(pk, m)) = m.$$

这里的等式忽略加密算法内部随机性的写法，表示所有合法加密都能被对应私钥正确解密。

11.3 公钥为什么可以公开

任何人都能使用 pk 加密，却只有掌握 sk 的人能够解密。攻击者可以：

- 获得 pk ；
- 自己运行 $E(pk, m)$ ；
- 比较和分析任意加密结果。

因此，公钥加密的安全定义从一开始就假设攻击者知道公钥。

12. 公钥加密的语义安全

12.1 IND-CPA 实验

1. 挑战者运行：

$$(pk, sk) \leftarrow G();$$

2. 把 pk 交给攻击者;
3. 攻击者选择两条等长消息:

$$m_0, m_1, \quad |m_0| = |m_1|;$$

4. 挑战者随机选择 $b \in \{0, 1\}$, 返回:

$$c \leftarrow E(pk, m_b);$$

5. 攻击者输出猜测 b' 。

优势可以写成:

$$\text{Adv}_{SS}[A, E] = |\Pr[EXP(0) = 1] - \Pr[EXP(1) = 1]|.$$

若所有高效攻击者的优势都可忽略, 则方案具有语义安全, 也称 IND-CPA 安全。

12.2 为什么不需要单独提供加密 oracle

在对称加密中, 攻击者不知道密钥, 需要挑战者提供加密 oracle。在公钥加密中, 攻击者已经知道 pk , 可以自己运行随机化算法 $E(pk, \cdot)$ 。因此加密查询能力是天然具备的。

12.3 加密必须随机化

如果公钥加密是确定性的, 攻击者收到挑战密文后可以自行计算:

$$E(pk, m_0)$$

和:

$$E(pk, m_1),$$

再直接比较, 立即识别挑战消息。因此, 普通公钥加密必须使用随机化或等价机制。

13. 使用公钥加密建立共享秘密

13.1 基本协议

Alice:

1. 生成密钥对:

$$(pk, sk) \leftarrow G();$$

2. 把 pk 发给 Bob。

Bob:

1. 随机选择 128 位秘密:

$$x \leftarrow \{0, 1\}^{128};$$

2. 计算:

$$c = E(pk, x);$$

3. 把 c 发给 Alice。

Alice 解密：

$$x = D(sk, c).$$

双方再从 x 派生会话密钥：

$$K_{session} = KDF(x, transcript, context).$$

13.2 为什么抵抗被动窃听

窃听者看到：

$$pk \text{ 和 } E(pk, x).$$

若公钥加密方案语义安全，则攻击者不能区分随机 x 的加密与另一随机消息的加密。因此，它无法恢复 x ，随后也无法得到从 x 派生的会话密钥。

13.3 这是密钥传输，不是对称协商

在这个协议中， x 由 Bob 单方面选择，再通过公钥加密传输给 Alice。因此更准确地说，它是：

key transport, 密钥传输。

Diffie-Hellman 中共享秘密由 a 和 b 双方共同贡献，任何一方单独都不能预先决定完整结果。

14. 公钥替换的中间人攻击

14.1 攻击过程

基础公钥传输协议仍然没有认证公钥。

1. Alice 发送 pk ;
2. Mallory 截获 pk ，生成自己的密钥对：

$$(pk', sk') \leftarrow G();$$

3. Mallory 把 pk' 冒充 Alice 的公钥发给 Bob;
4. Bob 选择 x ，并发送：

$$c' = E(pk', x);$$

5. Mallory 使用 sk' 解密得到 x ;
6. Mallory 可以再计算 $E(pk, x)$ 转发给 Alice。

Alice 和 Bob 最后可能得到同一个 x ，但 Mallory 也知道 x ，因此保密性完全失效。

14.2 公钥最重要的问题

不是“这个公钥能否用于加密”，而是：

这个公钥是否真的属于声称的身份？

解决方法包括：

- 证书颁发机构签发的证书；
- 预先保存的公钥或公钥指纹；
- Web of Trust；
- DNSSEC/DANE 等可信绑定；
- 通过其他认证信道核对指纹。

15. DH 与公钥密钥传输的比较

比较项	Diffie-Hellman	公钥加密密钥传输
共享秘密来源	双方秘密指数共同决定	一方随机选择并加密传给另一方
网络消息	g^a 、 g^b	pk、 $E(pk,x)$
被动安全基础	CDH/DDH 等群假设	公钥加密语义安全
是否天然认证	否	否
基础方案的主动攻击	替换 DH 公共值	替换公钥
获得认证的方法	签名、证书、PSK MAC 等	认证公钥、证书等
前向保密潜力	使用临时指数时可以提供	静态私钥传输通常不提供

15.1 前向保密

如果使用临时 DH 指数 a 、 b ，并在会话结束后销毁它们，那么未来长期身份密钥泄露时，攻击者通常不能仅凭历史流量恢复过去的 g^{ab} 。这称为 Forward Secrecy，前向保密。

若 Bob 把 x 加密到 Alice 的长期静态公钥，攻击者记录密文，并在未来得到 Alice 的私钥 sk ，就可以解密历史密文并恢复 x 。因此，基础静态公钥密钥传输通常没有前向保密。

这是从本课基础方案向现代安全协议延伸的重要区别。

16. 攻击模型对照

攻击者类型	能力	本课基础方案的情况
被动窃听者	读取全部网络消息	TTP 玩具协议、Merkle Puzzles、DH、语义安全公钥传输可抵抗
重放攻击者	重新发送旧消息	无新鲜性机制的 TTP 玩具协议不安全
主动中间人	拦截、替换、插入和转发	未认证 DH 与未认证公钥传输不安全
长期密钥泄露者	未来获得长期密钥并分析旧流量	静态密钥传输通常无前向保密

学习密钥交换协议时，必须先问清楚攻击者属于哪一种模型。讲义中“安全”的多个基础方案都明确限定为 eavesdropping security only。

17. 常见误区

误区 1: n 个用户一共只需要 $O(n)$ 把两两共享密钥

错误。每个用户需要 $O(n)$ 把，整个系统需要 $O(n^2)$ 对关系。使用 TTP 后，整个系统才可以只维护 $O(n)$ 份用户长期密钥。

误区 2: 加密 ticket 就自动防止重放

错误。旧 ticket 本身仍是合法密文。没有 nonce、时间戳或状态时，Bob 无法判断它是否属于旧会话。

误区 3: Merkle Puzzles 中 Bob 要解开所有 puzzles

错误。Bob 随机选择一个，只破解这一个。窃听者不知道标识对应哪一个，才可能需要破解许多 puzzles。

误区 4: Diffie-Hellman 发送的是共享密钥

错误。网络上传输的是 g^a 和 g^b ，共享值 g^{ab} 由双方本地计算。

误区 5: 知道 g^a 就能把指数 a 除出来

错误。群指数运算不是普通整数乘法，逆向恢复 a 是离散对数问题。

误区 6: DH 数学问题困难，所以协议天然认证

错误。困难假设防止窃听者从真实公共值计算共享秘密，却不能阻止攻击者把公共值换成自己的。

误区 7: 只要后续使用 AEAD，就能弥补未认证 DH

错误。中间人分别掌握与两端的会话密钥，可以合法生成两边的 AEAD 密文与标签。

误区 8: 公钥公开意味着任何人都可以解密

错误。任何人可以加密，只有对应私钥持有者可以解密。

误区 9: 收到一个格式正确的公钥，就知道它属于 Bob

错误。公钥与身份的绑定必须通过证书、预共享指纹或其他可信认证方式建立。

误区 10: 直接把 g^{ab} 的字节编码当成 AES 密钥即可

错误。应通过 KDF 提取并绑定会话上下文，再派生不同方向和用途的密钥。

误区 11: 课程中的历史参数表就是今天的推荐配置

错误。安全参数会随算法与计算能力变化。课程表格用于比较有限域和椭圆曲线的规模差异，实际部署应遵循当前标准。

18. 必记公式

两两预共享密钥总数：

$$\binom{n}{2} = \frac{n(n-1)}{2} = O(n^2).$$

Merkle Puzzles 工作量：

$$W_{Alice} = O(n), \quad W_{Bob} = O(n), \quad W_{Eve} = O(n^2).$$

DH 公开值：

$$A = g^a, \quad B = g^b.$$

DH 共享秘密：

$$K = B^a = (g^b)^a = g^{ab} = (g^a)^b = A^b.$$

CDH：

$$DH_g(g^a, g^b) = g^{ab}.$$

ECDH：

$$a(bG) = abG = b(aG).$$

公钥加密正确性：

$$D(sk, E(pk, m)) = m.$$

公钥密钥传输：

$$x \leftarrow \{0, 1\}^{128}, \quad c = E(pk, x), \quad x = D(sk, c).$$

会话密钥派生：

$$K_{session} = KDF(shared\ secret, transcript, context).$$

19. 自测题

题目

1. n 个用户两两预共享不同密钥时，每个用户和整个系统分别需要多少密钥关系？
2. 在线 TTP 方案如何把密钥管理规模降为 $O(n)$ ？
3. TTP 玩具协议为什么只能声称抵抗窃听，而不能抵抗重放？
4. Merkle puzzle 中的密钥为什么写成 $0^{96} \parallel P$ ？
5. 为什么 Bob 只需 $O(n)$ 工作，而窃听者约需 $O(n^2)$ ？
6. 写出 Diffie-Hellman 的两个公开值和共享秘密。
7. Alice 为什么能从 $B = g^b$ 计算 g^{ab} ？
8. DLP、CDH 与 DDH 的目标分别是什么？
9. 为什么不建议直接把群元素 g^{ab} 当作 AES 密钥？
10. 椭圆曲线 DH 中 aG 和 bG 分别代表什么？

11. 中间人如何在未认证 DH 中分别与 Alice、Bob 建立两把密钥？
12. 数字签名或证书在认证 DH 中解决什么问题？
13. 公钥加密为何通常必须是随机化的？
14. 为什么公钥加密的 CPA 实验不必给攻击者单独的加密 oracle？
15. 公钥密钥传输为何仍会受到中间人攻击？
16. key agreement 与 key transport 有什么区别？
17. 基础 AEAD 为什么不能单独修复已遭中间人攻击的密钥交换？
18. 临时 DH 为什么可能提供前向保密？

参考答案

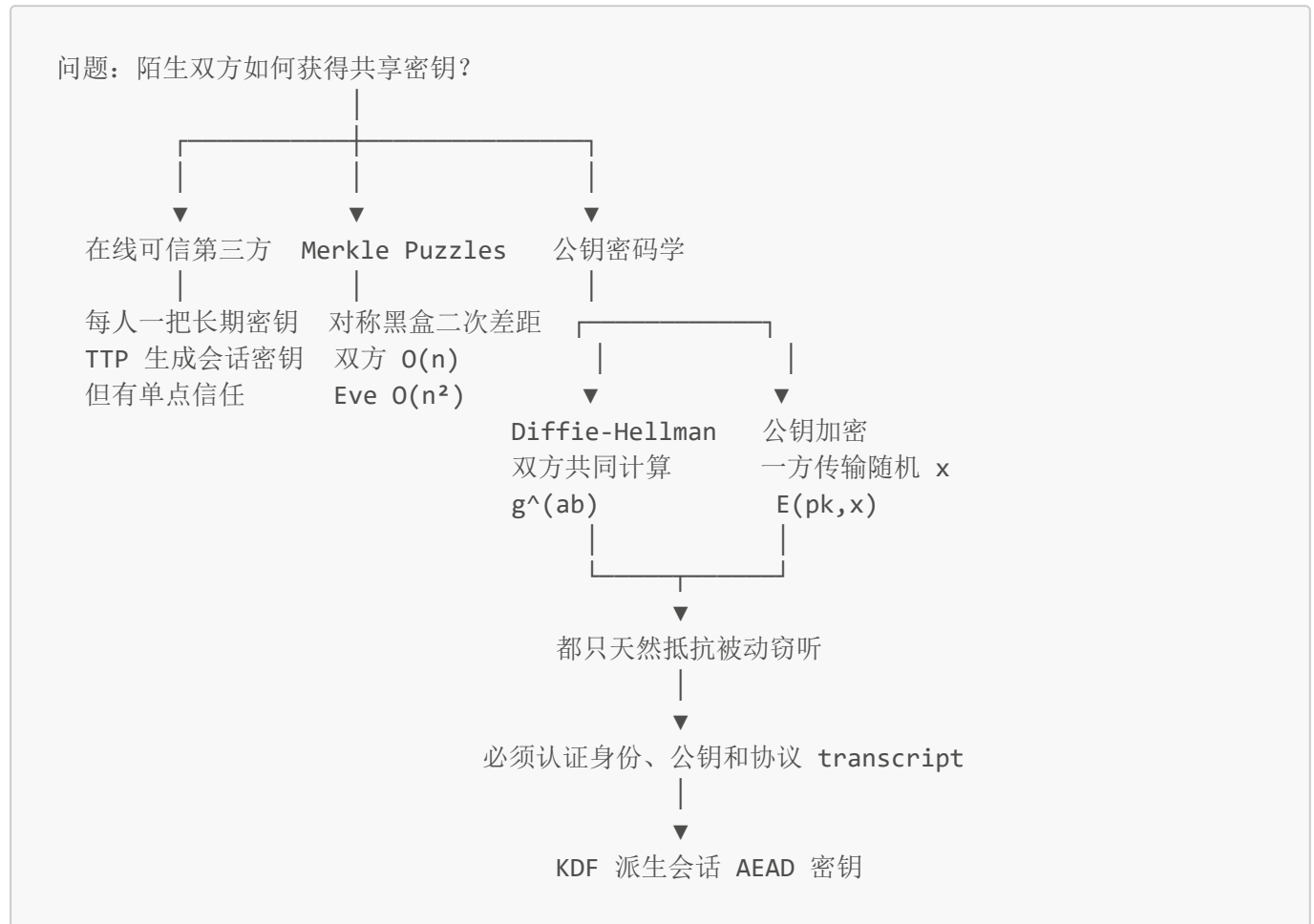
1. 每个用户保存 $n-1=O(n)$ 把；整个系统有 $n(n-1)/2=O(n^2)$ 个用户对。
2. 每个用户只与 TTP 共享长期密钥，由 TTP 按需生成并分别加密会话密钥。
3. 旧 ticket 仍能正确解密。没有 nonce、时间戳或状态时，Bob 无法判断它是否为旧消息。
4. 完整密钥仍为 128 位，但只有 P 的 32 位未知，让一个 puzzle 可以通过约 2^{32} 次枚举解决。
5. Bob 随机挑一个 puzzle，只需破解一次；窃听者不知道公开标识对应哪一个，可能要破解约 n 个 puzzle，每个又花 n 。
6. $A=g^a$ 、 $B=g^b$ ，共享秘密为 $B^a=A^b=g^{(ab)}$ 。
7. Alice 知道自己的秘密指数 a ，可以计算 $(g^b)^a=g^{(ab)}$ 。
8. DLP 求 a ；CDH 从 g^a 、 g^b 计算 $g^{(ab)}$ ；DDH 判断给定 T 是否等于 $g^{(ab)}$ 。
9. 群元素编码未必是均匀密钥，而且还需绑定身份和协议上下文，并派生多个用途密钥。
10. 它们是秘密标量 a 、 b 与公开基点 G 的标量乘法结果，即双方的临时公钥。
11. 攻击者替换双方公开值，用自己的两个秘密指数分别计算与 Alice、Bob 的共享密钥。
12. 把临时 DH 公共值与真实身份绑定，使攻击者不能在不被发现的情况下替换它。
13. 否则攻击者知道 pk ，可自行加密 m_0 、 m_1 并与挑战密文比较。
14. pk 是公开的，攻击者可以自己运行 $E(pk, \cdot)$ 。
15. 攻击者可以把 Alice 的 pk 替换成自己的 pk' ，解密 Bob 发回的秘密后再转发。
16. key agreement 的结果由双方秘密共同贡献；key transport 由一方选择秘密再安全传给另一方。
17. 中间人已经分别拥有两端的合法会话密钥，因此可以生成正确的 AEAD 标签并转发流量。
18. 会话结束后销毁临时指数，未来长期身份密钥泄露也不足以从历史公开值恢复旧共享秘密。

20. 一页复习提纲

1. 两两预共享密钥：每人 $O(n)$ ，全系统 $O(n^2)$ ，难以扩展。
2. 在线 TTP 让每个用户只维护长期密钥，由 TTP 生成会话密钥，但 TTP 必须在线并知道所有会话密钥。
3. 加密 ticket 不自动防重放；需要 nonce、时间戳、序列号或协议状态。
4. Merkle Puzzles 仅用对称密码实现密钥交换：双方 $O(n)$ ，窃听者 $O(n^2)$ 。
5. 黑盒对称密码下，Merkle Puzzles 的二次差距大致已是最优。
6. DH：Alice 发 g^a ，Bob 发 g^b ，双方计算 $g^{(ab)}$ 。
7. 窃听者要从 g^a 、 g^b 计算 $g^{(ab)}$ ，对应 CDH 问题。
8. DLP 求指数，CDH 求共享值，DDH 判断共享值真伪。
9. 实际应通过 KDF 从 DH 群元素派生会话密钥并绑定 transcript。
10. 椭圆曲线 DH 使用 aG 、 bG 和 abG ，在相近安全级别下参数更短。
11. 未认证 DH 会受到中间人攻击，因为公共值没有与身份绑定。
12. 公钥加密由 G 、 E 、 D 组成，公钥公开，私钥保密，加密通常随机化。
13. 公钥语义安全实验中攻击者天然能自行加密，因为它知道 pk 。

14. 可把随机 x 加密到接收方公钥来传输会话秘密，但公钥必须经过认证。
15. DH 是双方共同协商；公钥加密方案通常是单方向密钥传输。
16. 临时认证 DH 可以提供前向保密，静态公钥密钥传输通常不能。
17. 本课所有基础方案都要先区分：只抵抗窃听，还是抵抗主动攻击。

21. 本课关系图



本课最重要的结论是：**建立秘密与确认对方身份是两个不同问题**。**Diffie-Hellman 或公钥加密可以隐藏会话秘密，但只有经过认证的密钥交换才能抵抗主动中间人。**